

1. Write a brief explanation (in your own words) of what VAPT (Vulnerability Assessment and Penetration Testing) is, and list two differences between Vulnerability Assessment and Penetration Testing.

- Vulnerability Assessment and Penetration Testing (VAPT) is a cybersecurity process used to identify, analyze and test security weaknesses in systems, networks, applications and databases. It helps organizations to discover vulnerabilities before attackers can exploit them and recommends ways to fix them.
- **Difference between Vulnerability Assessment and Penetration Testing**

Vulnerability Assessment	Penetration Testing
Identifies and reports potential security vulnerabilities.	Actively tests Vulnerabilities to determine whether they can actually be exploited.
Usually performed using automated scanning tools.	Involves manual testing and controlled attack techniques by security professionals.

2. Imagine you are performing a VAPT for a food delivery app like Zomato. Identify and describe three common vulnerabilities you would check for in such an app.

- **Three common vulnerabilities to check in food delivery app while VAPT**

No	Vulnerability	Description
1	Broken Authentication and Authorization	Check whether users can access another user's account, order history, addresses or personal information by changing account IDs or manipulating requests. Weak passwords and improper session management should also be tested.

2	SQL Injection	Check whether user input fields such as search boxes, login forms or restaurant IDs improperly interact with the database. An attacker could potentially manipulate database queries and access or modify sensitive information.
3	Insecure API Security	Food delivery apps heavily depend on APIs for login, orders, payments and delivery tracking. Testers check whether APIs properly validate user permissions, expose sensitive data or allow unauthorized actions such as modifying another user's order.

3. Create a sample VAPT report template in a Word or Google Docs file for a fictional e-wallet app (like Paytm). Your template should include sections for Executive Summary, Methodology, Vulnerabilities Found, Risk Ratings, and Recommendations.

1) Document Control

Application	PaySecure – Fictional E-wallet Application
Assessment Type	VAPT
Assessment Period	01 September 2026 – 05 September 2026
Prepared by	Security Testing Team
Document Version	1.0

2) Executive Summary

- This sample VAPT report presents the security assessment of PaySecure a fictional e-wallet application used for wallet top-ups, peer-to-peer transfers, bill payments and transaction history. The assessment focused on identifying weaknesses that could affect confidentiality, Integrity and availability for user accounts and financial transactions.
- The assessment identified sample findings across authentication, authorization, input validation and data protection. Each finding should be validated and prioritized based on its business impact before production release.

3) Scope and Objectives

Scope:

- Web and mobile application interfaces.
- Authentication, session management and password reset functions.
- Wallet balance, money transfer and transaction history features.
- Selected application programming Interfaces (APIs).

Objectives:

- Identify exploitable security weaknesses.
- Assess the potential impact on users and business operations.
- Provide practical remediation recommendations.

4) Methodology

Phase	Activities
Information Gathering	Reviewed application functionality, endpoints and available documentation.
Vulnerability Assessment	Used manual checks and approved security testing tools to identify weaknesses.
Penetration Testing	Safely validated selected findings in a test environment without causing real financial transactions.

Risk analysis	Evaluated likelihood and business impact to sign risk ratings.
Reporting	Documented evidence, affected areas, risks and remediation actions.

5) Vulnerabilities Found

ID	Vulnerability	Affected Area	Risk	Status
VAPT-01	Weak Password Policy	User Authentication	Medium	Open
VAPT-02	Missing Authorization Check	Transaction API	High	Open
VAPT-03	Insufficient Input Validation	Bill payment API	Medium	Open
VAPT-04	Sensitive Data Exposure in Logs	Application Logs	Low	Open

6) Risk Ratings

Rating	Meaning	Typical Impact	Suggested Priority
Critical	Immediate and severe exposure	Major financial, data or service compromise.	Fix immediately

High	Significant security weakness	Unauthorized access or major business impact	Fix as soon as possible
Medium	Moderate security weakness	Limited compromise or increase attack surface	Plan and remediate promptly.
Low	Minor weakness	Limited impact under specific conditions	Fix during normal maintenance

7) Recommendations

- Implement strong authentication and optional multi-factor authentication for sensitive operations.
- Apply server-side authorization checks to every wallet, payment and transaction request.
- Validate and sanitize all user inputs using allow-list rules and secure coding practices.
- Protect sensitive information through encryption in transit and at rest.
- Remove secrets and unnecessary personal or financial data from application logs.
- Conduct secure code review and repeat VAPT testing after remediation.
- Maintain dependency updates, security monitoring and an incident response process.

- 4. Given the following scenario: During a VAPT of a movie ticket booking app, you discover that user passwords are stored in plain text in the database. Write a short VAPT report entry describing this vulnerability, its risk level, and a recommendation to fix it.**

VAPT Report

Description

- During the VAPT assessment of the movie ticket booking application. It was discovered that user passwords are stored in plain text in the database. This means that anyone who gains unauthorized access to the database can view user's passwords directly.

Risk Level – High

Impact

Plaintext password storage can lead to account compromise, unauthorized access to user accounts and data breaches. Attackers may also reuse exposed passwords on other websites if users have used the same password elsewhere.

Recommendation

Password should never be stored in plain text. The application should use a strong, one-way password hashing algorithm such as Argon2id, bcrypt or PBKDF2 along with unique salts for each password. Existing plaintext passwords should be securely migrated by forcing users to reset their passwords.